

Digital Policy Office

INFORMATION SECURITY

Practice Guide

for

Secure Use of USB Storage Devices

Version 3.1

July 2024

© The Government of the Hong Kong Special Administrative Region
of the People's Republic of China

The contents of this document remain the property of and may not be reproduced in whole or in part without the express permission of the Government of the Hong Kong Special Administrative Region of the People's Republic of China.
--

COPYRIGHT NOTICE

© 2024 by the Government of the Hong Kong Special Administrative Region of the People's Republic of China

Unless otherwise indicated, the copyright in the works contained in this publication is owned by the Government of the Hong Kong Special Administrative Region of the People's Republic of China. You may generally copy and distribute these materials in any format or medium provided the following conditions are met –

- (a) the particular item has not been specifically indicated to be excluded and is therefore not to be copied or distributed;
- (b) the copying is not done for the purpose of creating copies for sale;
- (c) the materials must be reproduced accurately and must not be used in a misleading context; and
- (d) the copies shall be accompanied by the words “copied/distributed with the permission of the Government of the Hong Kong Special Administrative Region of the People's Republic of China. All rights reserved.”

If you wish to make copies for purposes other than that permitted above, you should seek permission by contacting the Digital Policy Office.

Amendment History				
Change Number	Revision Description	Pages Affected	Revision Number	Date
1	Overall content review	Whole document	2.0	September 2020
2	Overall content review	Whole document	3.0	June 2022
3	Change “Office of the Government Chief Information Officer” (or “OGCIO”) to “Digital Policy Office” (or “DPO”)		3.1	July 2024

Table of Contents

1.	Introduction	1
1.1	Purpose	1
1.2	Normative References	1
1.3	Terms and Convention	2
1.4	Contacts	2
2.	Information Security Management.....	3
3.	Security Risks and Risk Management.....	5
3.1	Security Risks from USB Storage Devices	5
3.2	Risk Management of Using USB Storage Devices	5
3.3	Best Practices of Using USB Storage Devices.....	6
4.	Secure Use of USB Storage Devices.....	8
4.1	Disabling the use of USB Storage Devices	8
4.2	Securing USB Storage Devices with Classified Information.....	8
5.	Technical Consideration in Protecting Information Stored on USB Storage Devices	10
5.1	Hardware-based Encryption	10
5.2	Software-based Encryption	10
5.3	Comparison of Encryption Tools	11
	Annex A: Using Windows Group Policy to Control Access to USB Storage Devices	12
	Annex B: Managing BitLocker To Go for USB Storage Devices	13

1. Introduction

Universal Serial Bus (USB) storage devices, like thumb drives and external hard disks, are popular for storing and transporting data. However, their convenience also introduce security risks of data loss, data exposure, and malware attacks. This Practice Guide is developed to provide guidance notes for B/D's reference to formulating security policy and implementing appropriate technical measures to enforce secure use of USB storage devices.

1.1 Purpose

This Practice Guide would discuss the potential risks of using USB storage devices and the common practices to plan and control secure use of these devices in the offices. Guidance notes on how to protect information stored on USB storage devices and advisory on technical controls to enforce data encryption to protect classified information and person identifiable data stored on USB storage devices would be covered.

1.2 Normative References

The following referenced documents are indispensable for the application of this document.

- Baseline IT Security Policy [S17], the Government of Hong Kong Special Administrative Region
- IT Security Guidelines [G3], the Government of Hong Kong Special Administrative Region
- E-Memo - Risk Assessment for Processing, Storing and Viewing Personal/Classified Data Outside Office Environment, the Government of Hong Kong Special Administrative Region
- Circular Memorandum (Ref. CSO/AW L/M 2/2008) - Information Security Guidelines for Portable Electronic Storage Devices Circular, Director of Administration
- Guidance on the Use of Portable Storage Devices, Office of the Privacy Commissioner for Personal Data (PCPD)

1.3 Terms and Convention

For the purposes of this document, the terms and convention given in S17, G3, and the following apply.

Abbreviation and Terms	
AES	Advanced Encryption Standard
BIOS	Basic Input/Output System
DVD	Digital Versatile Disc
MBAM	Microsoft BitLocker Administration and Monitoring
OS	Operating System
PC	Personal Computer
PIN	Personal Identification Number
UEFI	Unified Extensible Firmware Interface

1.4 Contacts

This document is produced and maintained by the Digital Policy Office (DPO). For comments and suggestions, please send to:

Email:	itss@digitalpolicy.gov.hk
Lotus Notes mail:	IT Security Solutions/DPO/HKSARG@DPO
CMMP mail:	IT Security Solutions/DPO

2. Information Security Management

Information security is about the planning, implementation and continuous enhancement of security controls and measures to protect the confidentiality, integrity and availability of information assets, whether in storage, processing, or transmission and its associated information systems. Information security management is a set of principles relating to the functions of planning, organising, directing, controlling, and the application of these principles in harnessing physical, financial, human and informational resources efficiently and effectively to assure the safety of information assets and information systems.

Information security management involves a series of activities that require continuous monitoring and control. These activities include but not limited to the following functional areas:

- Security Management Framework and the Organisation;
- Governance, Risk Management, and Compliance;
- Security Operations;
- Security Event and Incident Management;
- Awareness Training and Capability Building; and
- Situational Awareness and Information Sharing.

Security Management Framework and Organisation

B/Ds shall establish and enforce departmental information security policies, standards, guidelines and procedures in accordance with the business needs and the government security requirements.

B/Ds shall also define the organisation structure on information security and provide clear definitions and proper assignment of security accountability and responsibility to involved parties.

Governance, Risk Management and Compliance

B/Ds shall adopt a risk based approach to identify, prioritise and address the security risks of information systems in a consistent and effective manner.

B/Ds shall perform security risk assessments for information systems and production applications periodically and when necessary so as to identify risks and consequences associated with vulnerabilities, and to provide a basis to establish a cost-effective security program and implement appropriate security protection and safeguards.

B/Ds shall also perform security audit on information systems regularly to ensure that current security measures comply with departmental information security policies, standards, and other contractual or legal requirements.

Security Operations

To protect information assets and information systems, B/Ds should implement comprehensive security measures based on their business needs, covering different technological areas in their business, and adopt the principle of “Prevent, Detect, Respond and Recover” in their daily operations.

- Preventive measures avoid or deter the occurrence of an undesirable event;
- Detective measures identify the occurrence of an undesirable event;
- Response measures refer to coordinated actions to contain damage when an undesirable event or incident occurs; and
- Recovery measures are for restoring the confidentiality, integrity and availability of information systems to their expected state.

Security Event and Incident Management

In reality, security incidents might still occur due to unforeseeable, disruptive events. In cases where security events compromise business continuity or give rise to risk of data security, B/Ds shall activate their standing incident management plan to identifying, managing, recording, and analysing security threats, attacks, or incidents in real-time. B/Ds should also prepare to communicate appropriately with relevant parties by sharing information on response for security risks to subdue distrust or unnecessary speculation. When developing an incident management plan, B/Ds should plan and prepare the right resources as well as develop the procedures to address necessary follow-up investigations.

Awareness Training and Capability Building

As information security is everyone's business, B/Ds should continuously promote information security awareness throughout the organisations and arrange training and education to ensure that all related parties understand the risks, observe the security regulations and requirements, and conform to security best practices.

Situational Awareness and Information Sharing

As cyber threat landscape is constantly changing, B/Ds should also constantly attend to current vulnerabilities information, threat alerts, and important notices disseminated by the security industry and the GovCERT.HK. The security alerts on impending and actual threats should be disseminated to and shared with those responsible colleagues within B/Ds so that timely mitigation measures could be taken.

B/Ds could make use of threat intelligence platforms to receive and share information regarding security issues, vulnerabilities, and cyber threat intelligence.

3. Security Risks and Risk Management

3.1 Security Risks from USB Storage Devices

USB storage devices, such as USB flash memory drives and external hard disks, are widely deployed as reusable memory storage and media to transport data between computers. The thumb-sized USB flash memory drives are no more than a few inches long but can store gigabytes of data and transfer gigabytes of data in a flash of seconds. The automatic installation of drivers and ease of use make USB storage devices a popular choice in the office and for personal use.

However, the thumb-sized USB storage devices are so small that they could be easily lost. If a lost or stolen USB storage device contains classified information or person identifiable data, it would constitute a data breach.

For those computers that allow the use of USB ports, attackers may use USB storage devices to download information from the host computer and other networked computers. The risk of data loss through unidentified USB storage devices should not be undermined.

Other than data security, it is possible that some malware would use USB storage devices to infect other computers. When a malware-infected USB storage device is plugged into a computer, the malware would infect that computer if it is not protected by appropriate security protection tools.

To avoid the above security risks, B/Ds shall put in place security controls and formulate security policy and procedures to govern the use of USB storage devices. For more detailed data security requirements and guidelines, B/Ds are advised to observe the relevant provisions specified in S17 and G3.

3.2 Risk Management of Using USB Storage Devices

In consideration of the high risks in data security and malware infection, B/Ds should conduct regular risk assessment and review the operation needs to allow the use of USB storage devices.

- (i) B/Ds should consider the use of other secure means to transport data and restrict the use of USB storage devices through stringent authorisation procedures. B/Ds should justify the need to store classified information to USB storage devices. Users should seek proper authorisation before storing required classified information on the USB storage devices and the USB storage devices in use shall be provided by B/Ds. B/Ds should document such authorisation and review the procedures on a regular basis;
- (ii) B/Ds should disable the USB support of those computers that have no operation needs to support these devices;
- (iii) B/Ds should enforce file-based / drive-based encryption and deploy password-protected USB storage devices; and

- (iv) B/Ds should make reference to the “Guidance on the Use of Portable Storage Devices” published by the Office of the Privacy Commissioner for Personal Data to assess the risk, and determine the appropriate type and amount of personal data that could be stored in USB storage devices.

3.3 Best Practices of Using USB Storage Devices

B/Ds should follow the best practices below in using USB storage devices for storing classified information:

- (i) Formulate policy, procedures and security measures to protect against the risks of using USB storage devices;
- (ii) Ensure compliance with the Personal Data (Privacy) Ordinance, particularly the Data Protection Principle 4 (on security of personal data), when handling personal data;
- (iii) Do not connect USB storage devices storing classified information to untrusted computers such as public kiosks;
- (iv) Do not connect unknown USB storage devices to B/Ds’ computers;
- (v) Enforce encryption of authorised USB storage devices (e.g. through Windows Group Policy) before users using the devices to store information. Encrypt all information stored in USB storage devices in order to minimise the risk and consequence of data loss¹;
- (vi) Disconnect USB storage devices storing classified information from computers when they are not in use;
- (vii) Ensure that all data has been completely cleared and cannot be restored from USB storage devices prior to disposal or re-use. For destruction and disposal of USB storage devices, requirements specified in “The Practice Guide for Destruction and Disposal of Storage Media”² shall be observed;
- (viii) Remove classified information from the USB storage devices once finished using them;
- (ix) Control access to USB storage devices with classified information and protect against unauthorised access, misuse or physical damage;
- (x) Manage the use and transportation of USB storage devices containing classified information;

¹ Encryption process may format the devices, prior backup of data stored in the devices should be conducted.

² [https://itginfo.ccgo.hksarg/content/itsecure/techcorner/practices/files/PG for Destruction and Disposal of Storage Media-v1.4_EN.pdf](https://itginfo.ccgo.hksarg/content/itsecure/techcorner/practices/files/PG%20for%20Destruction%20and%20Disposal%20of%20Storage%20Media-v1.4_EN.pdf)

- (xi) Keep an authorised equipment list and periodically performing inventory check for the status of USB storage devices stored with classified information;
- (xii) Report promptly the loss of USB storage devices and handle the incidents in accordance with the established security incident handling procedure; and
- (xiii) Enforce proper password rules and password handling mechanism to protect the passwords used to access the encrypted USB storage devices.

4. Secure Use of USB Storage Devices

This section provides guidance on different scenarios of securing USB storage devices for B/Ds' general references.

4.1 Disabling the use of USB Storage Devices

If there is no operation needs to use USB storage devices, B/Ds should consider the following means to prevent unauthorised access.

(i) Disable the use of computer peripheral ports in BIOS / UEFI

B/Ds can disable the use of computer peripheral ports³ in Basic Input / Output System (BIOS) or Unified Extensible Firmware Interface (UEFI)⁴ that included in the motherboard to prevent computers from connecting any unauthorised USB storage devices.

(ii) Block USB storage devices using OS built-in management tools

Alternatively, B/Ds can use the OS built-in management tools (e.g. Windows Group Policy) to control the read / write access of USB storage devices. Detailed information about the Windows Group Policy settings is given in **Annex A**.

4.2 Securing USB Storage Devices with Classified Information

If there is an operation needs to store classified information in USB storage devices, B/Ds should consider the following means to enforce data encryption on the USB storage devices.

(i) Built-in encryption tools in OS

(a) *Windows - BitLocker*

BitLocker is a drive encryption tool integrated in Microsoft Windows OS. In general, BitLocker Drive Encryption can encrypt internal hard drive, whilst the BitLocker To Go can encrypt USB storage devices. Detailed information of the deployment of BitLocker To Go is given in **Annex B**.

(b) *Mac OS – FileVault*

FileVault encryption is a drive encryption program provided in Mac OS,

³ For example, USB, FireWire, Wi-Fi, network, parallel port, serial port, PC Card slot (formerly known as PCMCIA slot), infrared and Bluetooth, etc.

⁴ Subject to models of PC / Notebook, options for disabling USB ports in BIOS / UEFI may not necessarily be available.

which supports full disk encryption for USB storage devices.⁵

(c) *Linux – dm-crypt*

Starting from Linux kernel version 2.6 and newer, a disk encryption subsystem, namely “dm-crypt” is provided. Dm-crypt can encrypt whole disk volume inclusive of USB storage. Different Linux distributions, such as Red Hat⁶, CentOS⁷, Ubuntu⁸ and OpenSUSE⁹, have provided documentation for using dm-crypt.

(ii) Other encryption tools

(a) *Enterprise Encryption software*

Generally, enterprise grade encryption software allow administrators to centrally manage the media encryption and peripherals port settings (e.g. USB) of client computers at the centralised management console. In general, the storage devices encrypted by a specific kind of software can only be decrypted by the corresponding software (e.g. BitLocker encrypted devices can only be decrypted by BitLocker but not by other encryption software).

(b) *Encryption tool in endpoint protection software*

Some endpoint protection software comes with encryption tool to let you encrypt files and USB storage devices. Some endpoint protection software also provides encryption key management.

(c) *Built-in encryption feature in USB storage devices*

Some USB storage devices also come with built-in encryption tool developed by the hardware manufacturer. This type of device is easy to deploy without additional encryption software installed.

⁵ <https://support.apple.com/en-us/HT204837>
<https://support.apple.com/en-hk/guide/mac-help/mh40593/mac>

⁶ Red Hat: https://access.redhat.com/documentation/en-US/Red_Hat_Enterprise_Linux/5/html/Installation_Guide/ch29s02.html

⁷ CentOS: <https://wiki.centos.org/HowTos/EncryptedFilesystem>

⁸ Ubuntu: <https://help.ubuntu.com/community/EncryptedFilesystemHowto>

⁹ openSUSE: https://en.opensuse.org/SDB:Encrypted_filesystems

5. Technical Consideration in Protecting Information Stored on USB Storage Devices

In general, encryption of data stored on USB storage devices can be achieved through hardware-based encryption or software-based encryption.

5.1 Hardware-based Encryption

Some USB storage devices (e.g. USB flash drives or hard disks) utilise hardware encryption in which microchips within the USB storage devices provide automatic and transparent encryption. Such type of USB storage devices with built-in encryption feature can be used readily without encryption software installation and is usually more expensive than similar storage devices without encryption feature.

The characteristics of hardware-based encryption:

- Ready for use with minimal configurations on the host PC;
- Use a dedicated processor inside the encrypted drive to off-load encryption from the host PC;
- Safeguard keys and critical security parameters within crypto-hardware; and
- Protect against common attacks, such as cold boot attacks, malicious code and brute force attacks.

5.2 Software-based Encryption

Microsoft Windows OS provide built-in encryption feature, namely “BitLocker” which is a drive encryption technology. Administrators can make use of Windows Group Policy to enforce BitLocker encryption and restrict the use of unencrypted USB storage devices.

Besides, there are other software encryption products which support encryption of specified files, directories, the whole data drive and various media including USB storage devices, CDs and DVDs. Moreover, enterprise grade encryption software and endpoint protection software usually bundles with central management suite which enables administrators to enforce encryption policy with the provision of reporting and auditing capabilities.

The characteristics of software-based encryption:

- Cost-effective in Windows environment using bundled BitLocker tools;
- Could be implemented on all types of USB storage devices;
- Share computing resources to process data encryption with other programs on the host system; and
- Allow software updates to fix vulnerabilities and keep up with protection measures.

5.3 Comparison of Encryption Tools

The following table highlights the difference of these encryption tools in terms of their estimated costs, pros and cons.

	Hardware-based Encryption	Software-based Encryption	
	USB Storage Devices with Encryption Feature	Built-in Tools in OS	Encryption and/or Endpoint Protection Software
Pros	• Support Windows, Mac and Linux platforms • Option to support centralised management • Automatic reformat the drives after pre-defined password attempts • Easy to deploy	• Integrated with OS • No extra cost to encrypt USB drives • Central governance using Group Policy to enforce BitLocker protection on USB storage devices (<i>for Windows BitLocker</i>)	• Support Windows, and Mac platforms • Support centralised management (e.g. policy-based control, provide management reports) • Support various type of media (e.g. USB drives, CD/DVD)
Cons	• May be costly if many devices are required	• Support corresponding OS platform only	• Additional resources are required (e.g. additional servers and skills)

The “Catalogue of IT Security Solutions (CoSS)” under the ITG InfoStation provides some encryption solutions for reference by B/Ds. B/Ds are encouraged to conduct their own research and evaluation in selecting the most suitable solutions that meet their business requirements.

The CoSS can be accessed via the government intranet:

- Storage Encryption Software:
<https://itginfo.ccgo.hksarg/content/coss/category/ses>
- USB Storage Device:
<https://itginfo.ccgo.hksarg/content/coss/category/usb>

Annex A: Using Windows Group Policy to Control Access to USB Storage Devices

A1. Administrator can use Window Group Policy to deny the read / write access to USB storage devices.

- (i) **Browse** to Computer Configuration > Administrative Templates > System > Removable Storage Access
- (ii) **Enable** the following settings:
 - Removable Disks: Deny execute access
 - Removable Disks: Deny read access
 - Removable Disks: Deny write access

	Setting	State	Comment
	Set time (in seconds) to force reboot	Not configured	No
	CD and DVD: Deny execute access	Not configured	No
	CD and DVD: Deny read access	Not configured	No
	CD and DVD: Deny write access	Not configured	No
	Custom Classes: Deny read access	Not configured	No
	Custom Classes: Deny write access	Not configured	No
	Floppy Drives: Deny execute access	Not configured	No
	Floppy Drives: Deny read access	Not configured	No
	Floppy Drives: Deny write access	Not configured	No
	Removable Disks: Deny execute access	Enabled	No
	Removable Disks: Deny read access	Enabled	No
	Removable Disks: Deny write access	Enabled	No
	All Removable Storage classes: Deny all access	Not configured	No
	All Removable Storage: Allow direct access in remote sessions	Not configured	No
	Tape Drives: Deny execute access	Not configured	No
	Tape Drives: Deny read access	Not configured	No
	Tape Drives: Deny write access	Not configured	No
	WPD Devices: Deny read access	Not configured	No
	WPD Devices: Deny write access	Not configured	No

Annex B: Managing BitLocker To Go for USB Storage Devices

B1. Using Windows Group Policy to Enforce BitLocker Encryption

BitLocker Group Policy settings can be accessed using the Local Group Policy Editor and the Group Policy Management Console (GPMC) under **Computer Configuration\Administrative Templates\Windows Components\BitLocker Drive Encryption**. How you configure these policy settings¹⁰ depends on how you implement BitLocker and what level of user interaction are allowed. The following BitLocker features on removable drives are recommended:

- (i) Enforce BitLocker encryption on USB storage devices;
- (ii) Ensure that the BitLocker encryption to USB storage devices could not be disabled by users; and
- (iii) Enforce the password complexity and password length if password protection is adopted for the BitLocker To Go drives.

B2. Recovery Options of BitLocker To Go

Recovery key is required for a user to gain access to the BitLocker protected drives when the user forgets the BitLocker password, loses smart card. When the USB storage devices is encrypted, you may choose the following methods to maintain the recovery key for the devices.

- (i) Print the recovery key;
- (ii) Save the recovery key to separate file; and

Handling the recovery key

The BitLocker recovery information must be protected against unauthorised access. B/Ds are recommended to store the BitLocker recovery key information in separate encrypted disk with proper protection, or print the file and seal it in envelope, and then keep the envelope in safe place. B/Ds should refer to section 12.1(b) – “Cryptographic Key Management” of G3 for guidelines on key management.

B/Ds may also adopt centralised management of the BitLocker recover key with MBAM.

To protect USB storage device containing classified information, B/Ds should avoiding uploading the respective recovery key information in any public cloud service platform such as the online Microsoft account.

¹⁰ How to configure the Group Policy Settings can be found at <https://docs.microsoft.com/en-us/windows/security/information-protection/bitlocker/bitlocker-group-policy-settings#bkmk-driveaccess3>

B3. Technical Measures for Securing BitLocker To Go

- (i) Administrators should disable hibernation to avoid dumping the RAM contents to a data file namely hiberfill.sys on the system root which would restore the preceding user environment when next startup.
- (ii) Administrators should disable the network shares of computers when accessing sensitive data on the USB storage devices to prevent unauthorised access to sensitive files stored in BitLocker protected drives mapped to network drives.
- (iii) Administrators have to enforce encryption on USB storage devices before writing data on them. This is to assure the data never stored in plain text as some flash-based memory using wear-leveling algorithm can expose data stored in plaintext.
- (iv) In case the BitLocker keys are compromised, administrators are required to remove any existing instances of BitLocker metadata by either formatting the entire drive or decrypt and encrypt the entire drive again. Otherwise, new BitLocker keys cannot be created because deleting the partition cannot invalidate the BitLocker metadata.
- (v) The BitLocker technology may be vulnerable to Direct Memory Access (DMA) attacks when the computer is turned on or is in the Standby power state. To mitigate the DMA attack, administrators can follow the resolutions from Microsoft at: <https://support.microsoft.com/en-us/kb/2516445>
- (vi) The BitLocker To Go disk can be unlocked automatically on specified computer. There is an option “Automatically unlock on this PC” in the “Manage BitLocker” menu. This option should be disabled to prevent the BitLocker protected drive unlocked automatically. Otherwise, the computer will cache the BitLocker password after logout or turn off so as to unlock the BitLocker protected drive next logon.

B4. Deploying BitLocker To Go in Your Office Environment

B/Ds shall observe and follow the requirements in S17 and G3 in deploying BitLocker To Go in your environment.

- (i) BitLocker To Go supports password or smart card to unlock the encrypted USB storage devices. For detailed security requirements about the key length, B/Ds should observe the relevant requirement specified in S17 and G3.
- (ii) B/Ds shall base on the level of protection required and the requirements of S17 and G3 to determine the BitLocker To Go encryption and recovery method.
- (iii) It is important to note that files remain encrypted when storing in the encrypted USB storage devices, but they are decrypted when after copying out to other system drives or transferring through the network. Users are reminded to

disconnect the USB storage devices from computers when they are not in use.

- (iv) Similar to other data at rest encryption technologies, BitLocker is also subject to memory vulnerabilities. Administrators should take note of the measures as mentioned in B3.

B5. References

- BitLocker Overview
<https://docs.microsoft.com/en-us/windows/security/information-protection/bitlocker/bitlocker-overview>
- Overview of BitLocker Device Encryption in Windows,
<https://docs.microsoft.com/en-us/windows/security/information-protection/bitlocker/bitlocker-device-encryption-overview-windows-10>
- BitLocker Group Policy settings,
<https://docs.microsoft.com/en-us/windows/security/information-protection/bitlocker/bitlocker-group-policy-settings>
- BitLocker To Go FAQ,
<https://docs.microsoft.com/en-us/windows/security/information-protection/bitlocker/bitlocker-to-go-faq>
- BitLocker Key Management FAQ,
<https://docs.microsoft.com/en-us/windows/security/information-protection/bitlocker/bitlocker-key-management-faq>